Secure Software Development

EGRMGMT 590.23.F19

Fall 2019

Instructor: Jonathan Knudsen <jonathan.knudsen@duke.edu>
Course Web Site: http://people.duke.edu/~jk471/egrmgmt590.23.f19/
Class: Thursdays 6:15pm - 9:00pm, Hudson Hall 232
Virtual office hours: Mondays at 7:00pm. Check the course web site for details.

Description

Software is woven into the fabric of society. When software fails, either accidentally or when under attack, the consequences can be severe. Creating software is incredibly easy. Creating safe, secure software is very challenging.

This course is about minimizing risk when creating software, using both an overall process as well as specific technologies. Students will learn the fundamental structure of a Secure Development Life Cycle (SDLC), the advantages and challenges of cryptography, then explore automated testing solutions. Students will learn what they need to know to effectively manage risk in the process of creating software.

The course alternates between lectures and workshops. The workshops provide hands-on experience with specific technologies and are coordinated with assignments. By the end of the course, students will have a firm grasp on the underlying technologies and be prepared to make informed decisions about the design, architecture, and implementation of software.

Assignments are focused mainly on automated vulnerability hunting tools. For each of the tool types, students will install an appropriate free tool and run it on a software project. As much as possible, students will use the same software project as target practice throughout the course. As the course progresses, students will have an increasingly clear view of the risk profile of the target software project, and an understanding of how these tools add value to the overall secure development life cycle.

Prerequisite

Some programming experience

Textbook

The Security Development Lifecycle, by Howard and Lipner. Free PDF or ePub:
https://blogs.msdn.microsoft.com/microsoft_press/2016/04/19/free-ebook-the-security-development-lifecycle/

Learning Objectives

- Learn how a better process (Secure Development Life Cycle) produces better software, by enabling teams to find and fix more design, configuration, and code vulnerabilities earlier
- Understand and use security testing tools: (a) static source code analysis, (b) software composition analysis, (c) fuzz testing, and (d) interactive application testing
- Use cryptography to preserve confidentiality and integrity
- Understand how Public Key Infrastructure (PKI) works together with Transport Layer Security (TLS) to enable commerce on the Web

Attendance

Class attendance is crucial to your success, as nearly all material we will cover is not in the book. Each class will include at least one quiz or graded activity.

Assignments

Assignments will be posted each week after the class and will be due at 12:15pm on the day of the next class.

Assignments are to be completed individually.

Grading

50% Assignments
    The two lowest assignment grades will be dropped; the remaining assignment grades will be averaged.
10% Quizzes
20% Midterm examination
20% Final examination